

האנטומיה של הנוזקה (Malware)

מיפוי, סיווג ודרכי התגוננות במרחב הסייבר המודרני.



האנטומיה של הנוזקה (Malware)

מיפוי, סיווג ודרכי התגוננות במרחב הסייבר המודרני.

איום גלובלי מתרחב

Malware (Malicious Software) היא תוכנה שנועדה במכוון לשבש, לדלוף, או למנוע גישה למערכות ולמידע, לרוב ללא ידיעת המשתמש.

היקף מוחלט



669 מיליון

וריאנטים של נזקות זוהו בשנה אחת (הכפלה של קצב הצמיחה).

נזק כלכלי



העלות השנתית המוערכת של פשיעת סייבר לכלכלה העולמית.

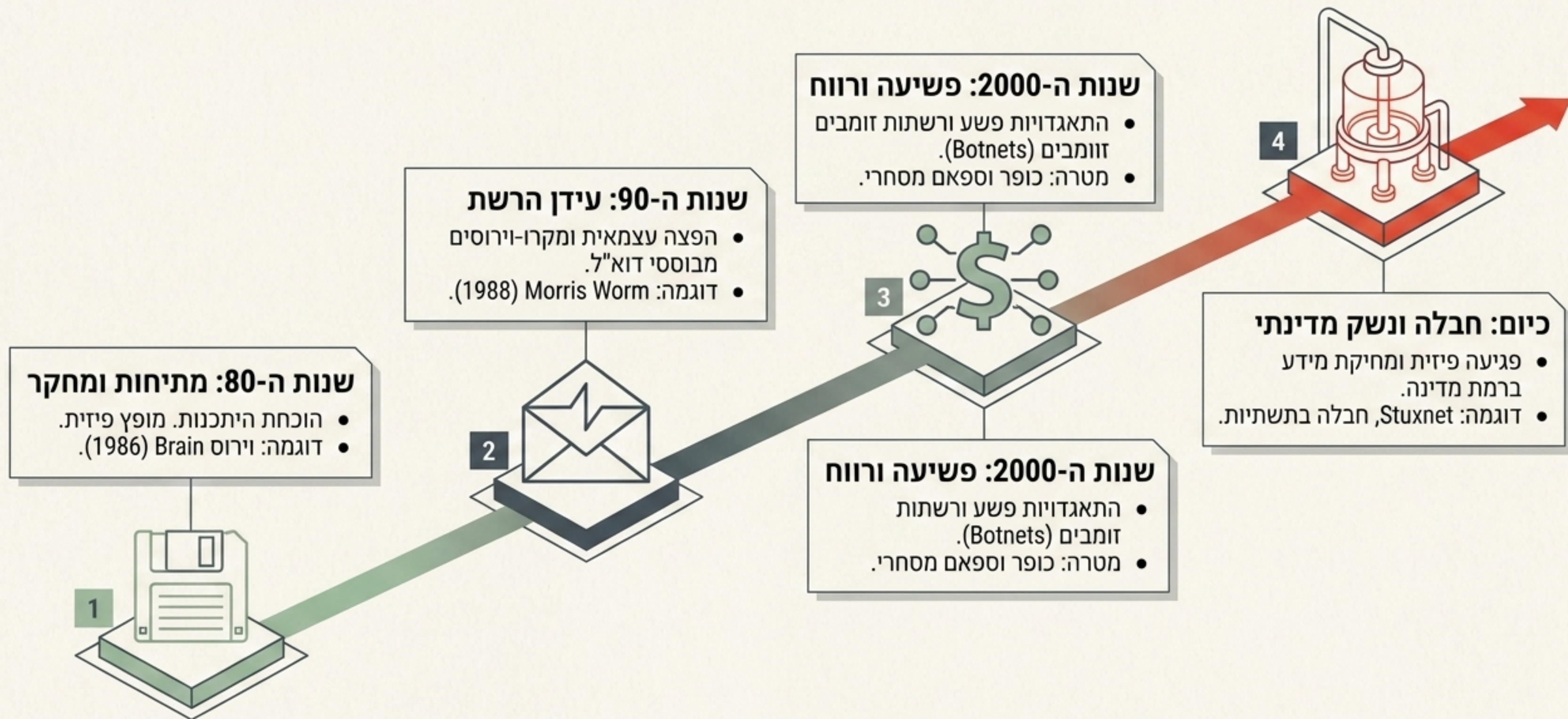
יעד אסטרטגי



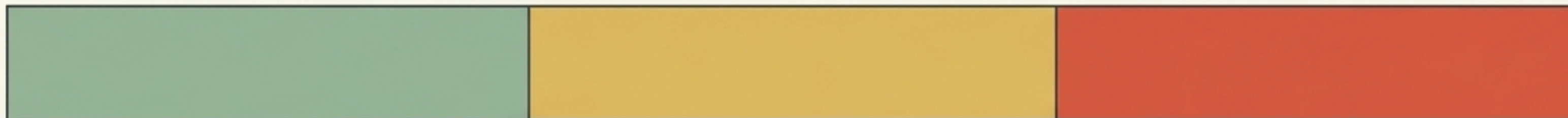
Critical Infrastructure

מעבר מתקיפת מחשבים אישיים לתקיפת תשתיות קריטיות כגון רשתות חשמל ומים.

מניסויים אקדמיים לנשק גיאופוליטי



ספקטרום התוכנות ומדד הכוונה הזדונית



Goodware

מקורות: אמינים וחוקיים.

מאפיין: עשויות להכיל באגים
טבעיים, אך ללא כוונת זדון
מתוכננת מראש.

Grayware

מקורות: חסר קונצנזוס
אבטחתי.

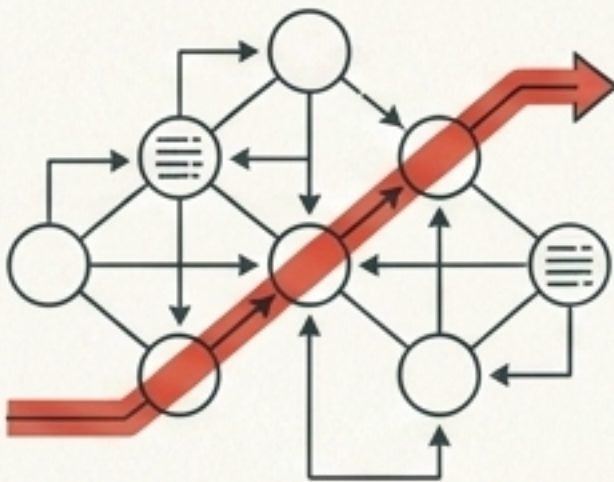
מאפיין: תוכנות לא רצויות
(PUPs). כולל Adware
(פרסומות כפויות) ו-
Spyware ללא אישור.

Malware

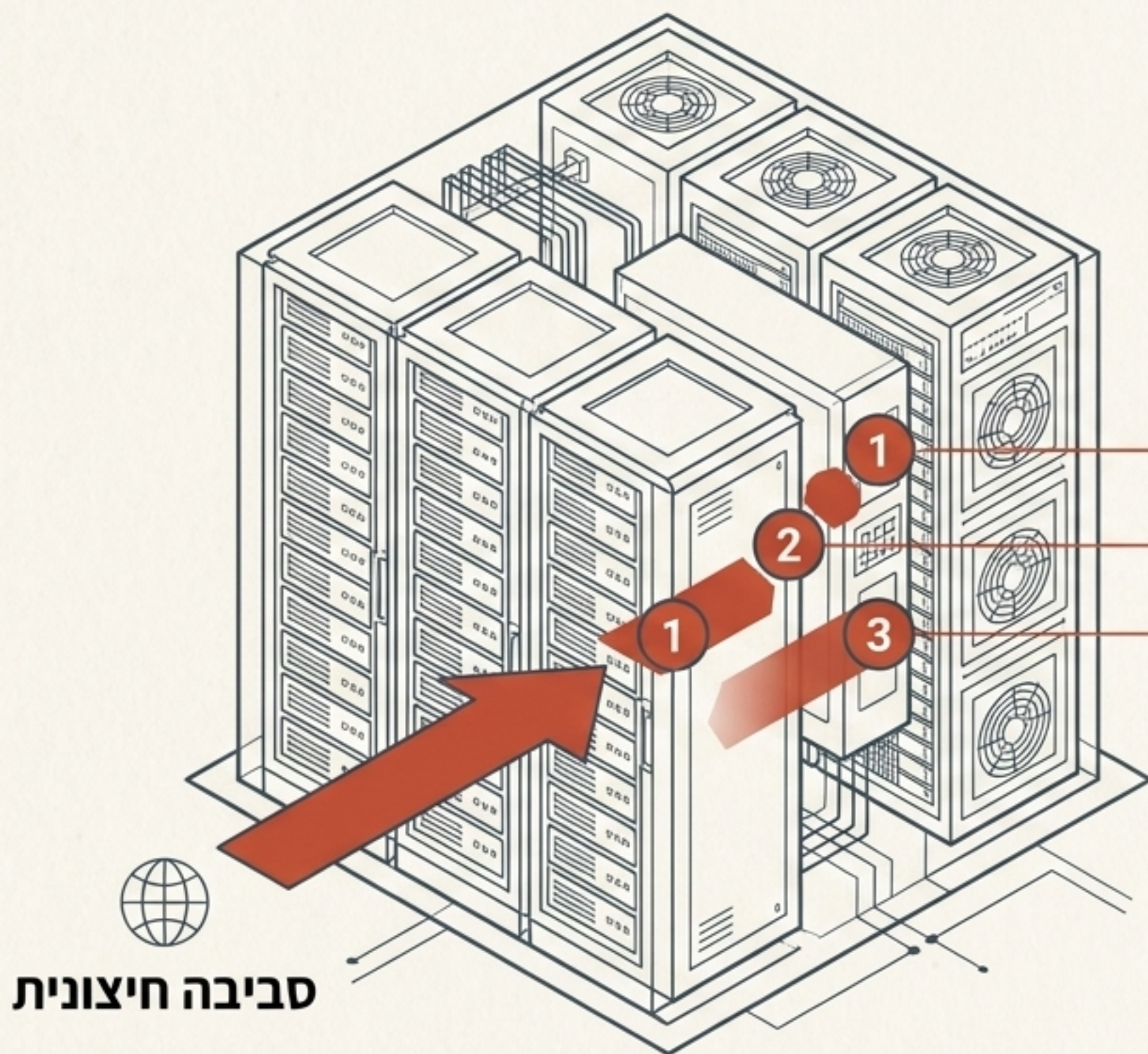
מקורות: עוינים (קונצנזוס
אנטי-וירוס מוחלט).

מאפיין: תוכנות המיועדות
לגרימת נזק, גניבה, או
חסימת גישה.
(וירוסים, כופרות).

וקטורי הפעולה המרכזיים: מבט השוואתי

		
Virus (וירוס)	Worm (תולעת)	Trojan Horse (סוס טרויאני)
• מנגנון פעולה: טפיל (Parasite). משבץ קוד בתוך קובץ מארח קיים. • התפשטות: פסיבית. דורש התערבות אקטיבית של המשתמש כדי לרוץ.	• מנגנון פעולה: ישות תוכנה עצמאית (Stand-alone). • התפשטות: אקטיבית. סורקת ומנצלת חולשות רשת אוטומטית, ללא מגע אדם.	• מנגנון פעולה: תחפושת (Disguise). מתחזה לתוכנה לגיטימית לחלוטין. • התפשטות: הנדסה חברתית. הלקוח מכניס אותו בעצמו. אינו משכפל את עצמו.

אנטומיה של חדירה: היררכיית התפקידים



1. השער (The Gate) - Droppers

תוכנה קלה שנוחתת במערכת באין מפריע, במטרה בודדת להוריד ולהחדיר את המטען הכבד מהאינטרנט אל הזיכרון.

2. הגשר (The Bridge) - Backdoors

יצירת ערוץ תקשורת חשאי העוקף אימות. מעניק לתוקף גישה מרחוק ושליטה רציפה (Persistent) במערכת (Persistent Access).

3. הגלימה (The Cloak) - Rootkits

שינוי עמוק של מערכת ההפעלה המארכת כדי להסתיר את הנוזקות מקריאה או מרשימת התהליכים של האנטי-וירוס.

מטענים ייעודיים (The Payloads)

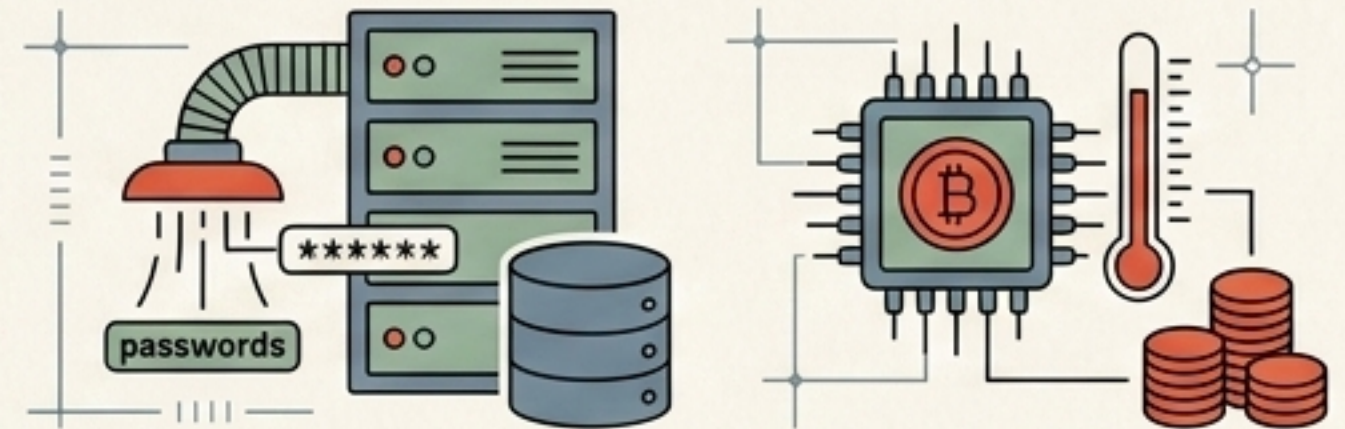
Рansomware (כופרה)

הפעולה: חסימת גישה למערכת (Locker) או הצפנה בלתי הפיכה של קבצים.
המטרה: דרישת דמי כופר קריפטוגרפיים תמורת מפתח השחרור.



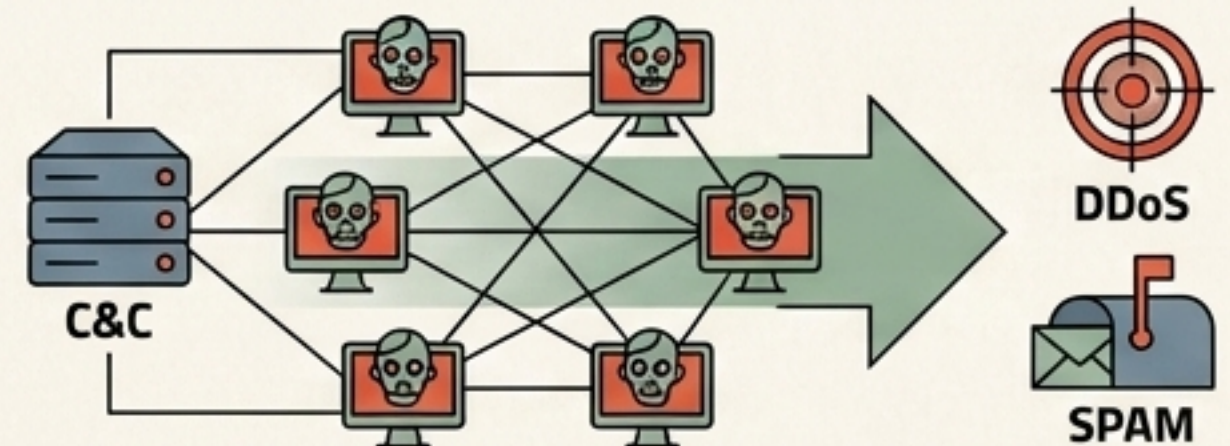
Infostealers & Cryptominers

הפעולה: שאיבת סיסמאות מוסוות (כמו Lumma Stealer) או ניצול שקט של משאבי העיבוד (CPU/GPU) לייצור מטבעות.
המטרה: רווח כספי חשאי במחיר האטה משמעותית של המערכת המארכת.



Botnets (רשתות זומבים)

הפעולה: הפיכת המחשב לחייל שקט בצבא סתרים הנשלט מרחוק.
המטרה: ייצור מסת אש לביצוע מתקפות מניעת שירות המוניות המוניות (DDoS) והפצת דואר זבל.



חורים בחומה: מדוע מערכות קורסות?

1. באגים בקוד (Vulnerable Software)

ניצול פגיעויות ידועות מראש (כגון הצפת זיכרון) לפני שהארגון התקין טלאי אבטחה (Patch).

2. הרשאות מוגזמות (Excessive Privileges)

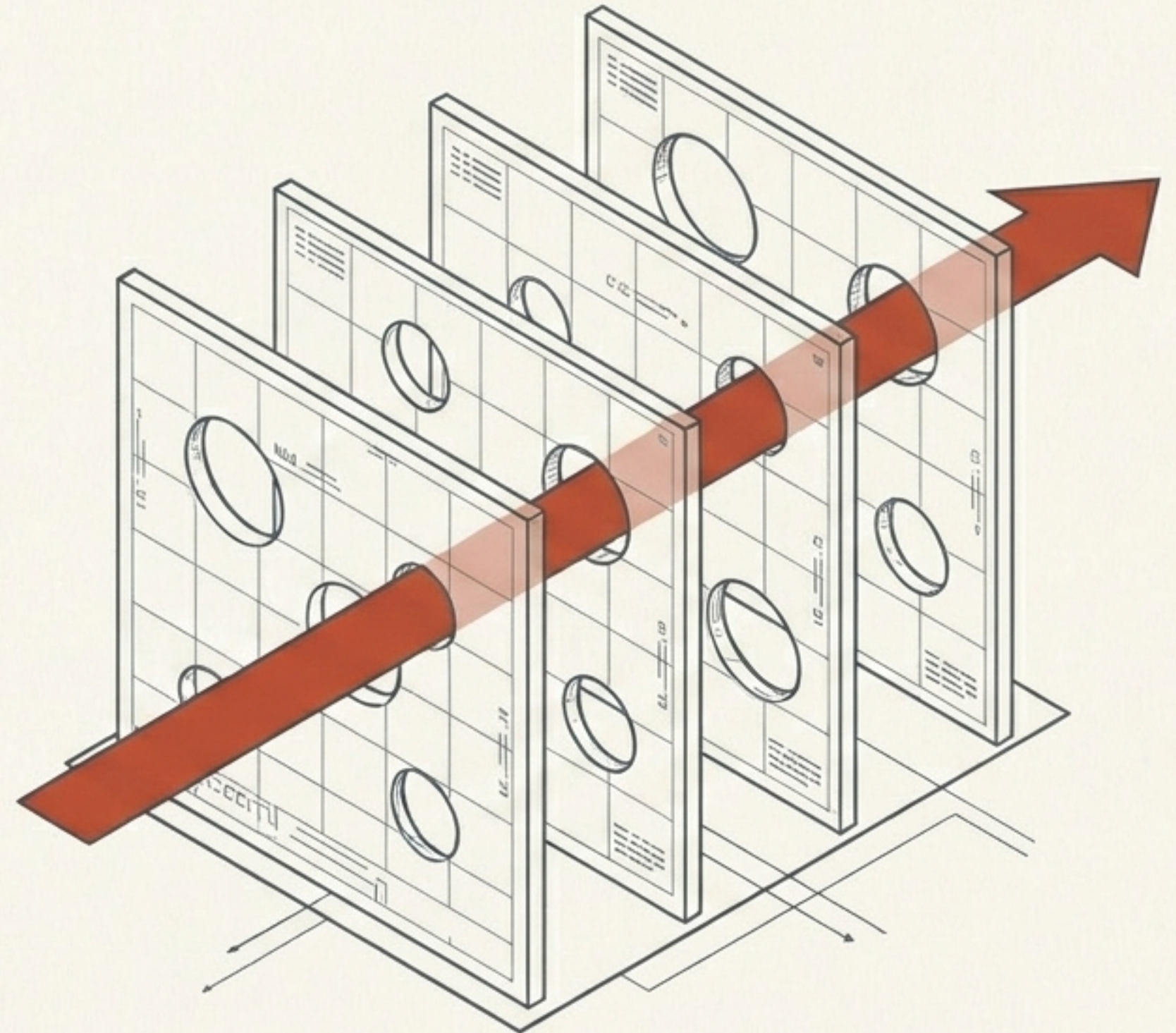
יישומים ומשתמשים הרצים עם גישת Root רחבה ללא צורך מעשי, המאפשרים לנוזקה להשתלט על הליבה.

3. סיסמאות חלשות (Credential Attacks)

פריצת חשבונות פריבילגיים על ידי כוח גס (Brute force).

4. אחידות מערכתית (Homogeneity)

רשת שכולה מריצה בדיוק את אותה מערכת הפעלה מאפשרת לוקטור אחד להפיל את כולה.



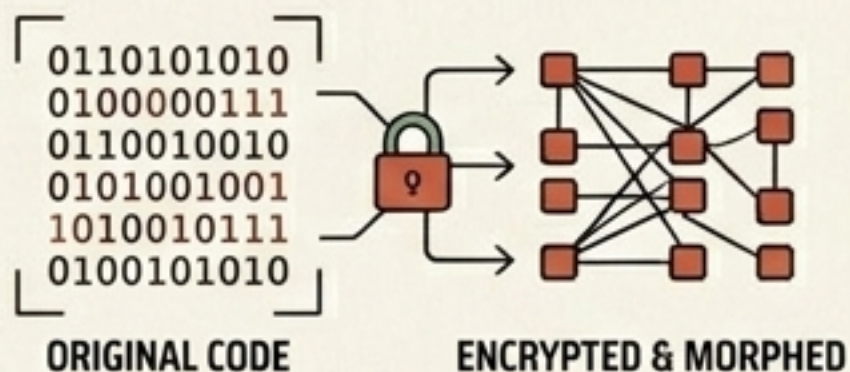
אמנות ההסוואה: טכניקות חמיקה (Evasion)

כ-33% מכלל הנוזקות מסוגלות לחמוק מזיהוי אנטי-וירוס באמצעות שיטות מתוחכמות.



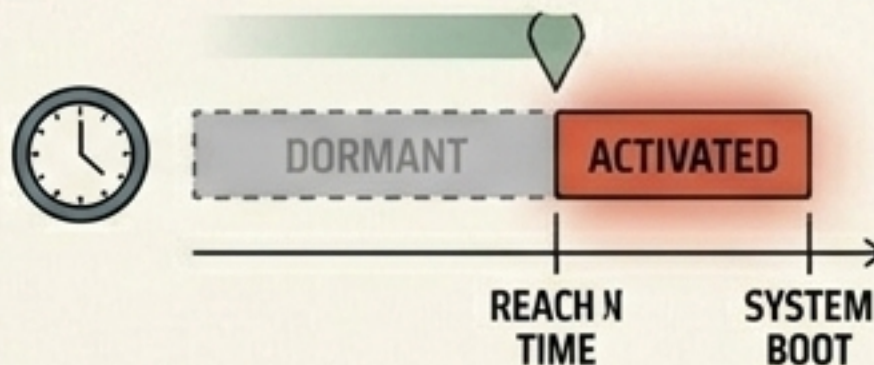
שינוי צורה והצפנה (Polymorphism)

הנוזקה מצפינה את עצמה ומשנה את הקוד הבינארי שלה בכל מחזור הדבקה. מונע זיהוי על בסיס חתימה קבועה.



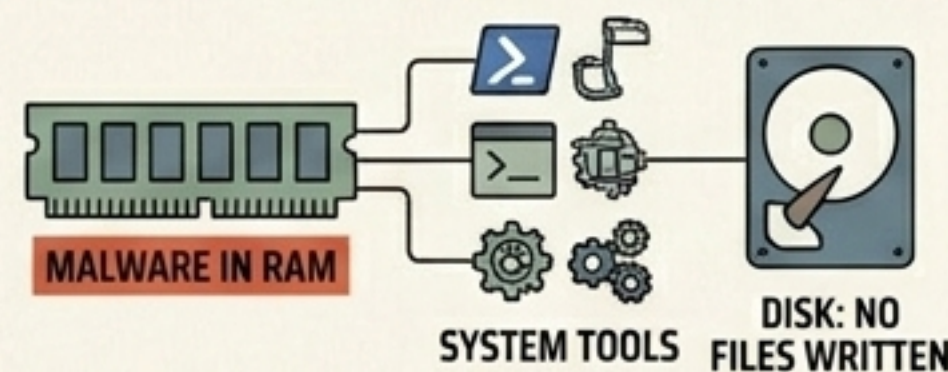
השהיה טקטית (Timing-based)

הקוד נותר רדום לחלוטין ומופעל רק בעת אירוע ספציפי (כמו אתחול המערכת) כדי לחמוק מסורקים אוטומטיים.



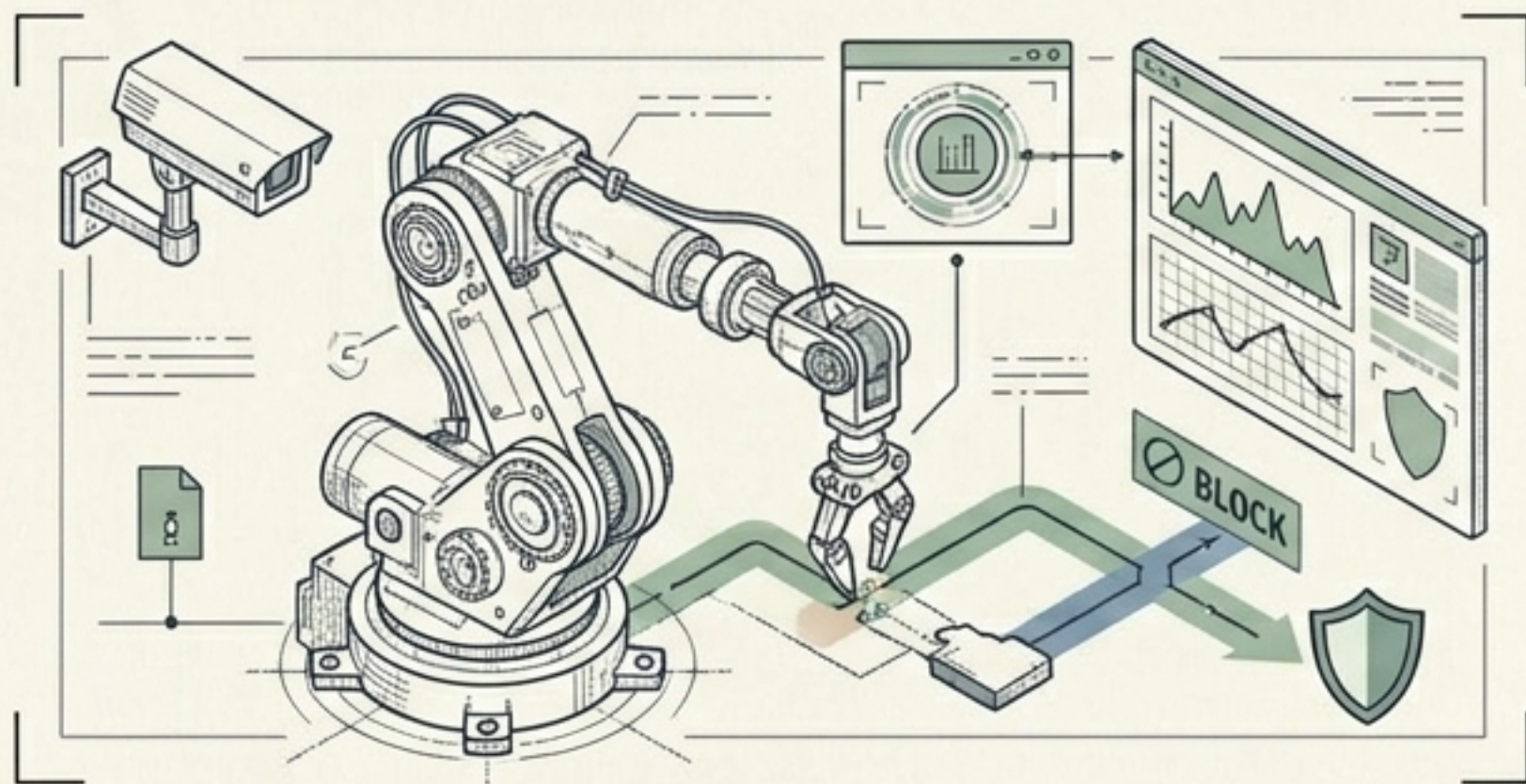
התבססות ללא קבצים (Fileless / LotL)

הנוזקה חיה בזיכרון ה-RAM בלבד ומשתמשת בכלים הלגיטימיים של המערכת, מבלי לכתוב קבצים מחשידים לדיסק.



מנגנוני זיהוי: מסדר זיהוי מול מעקב התנהגותי

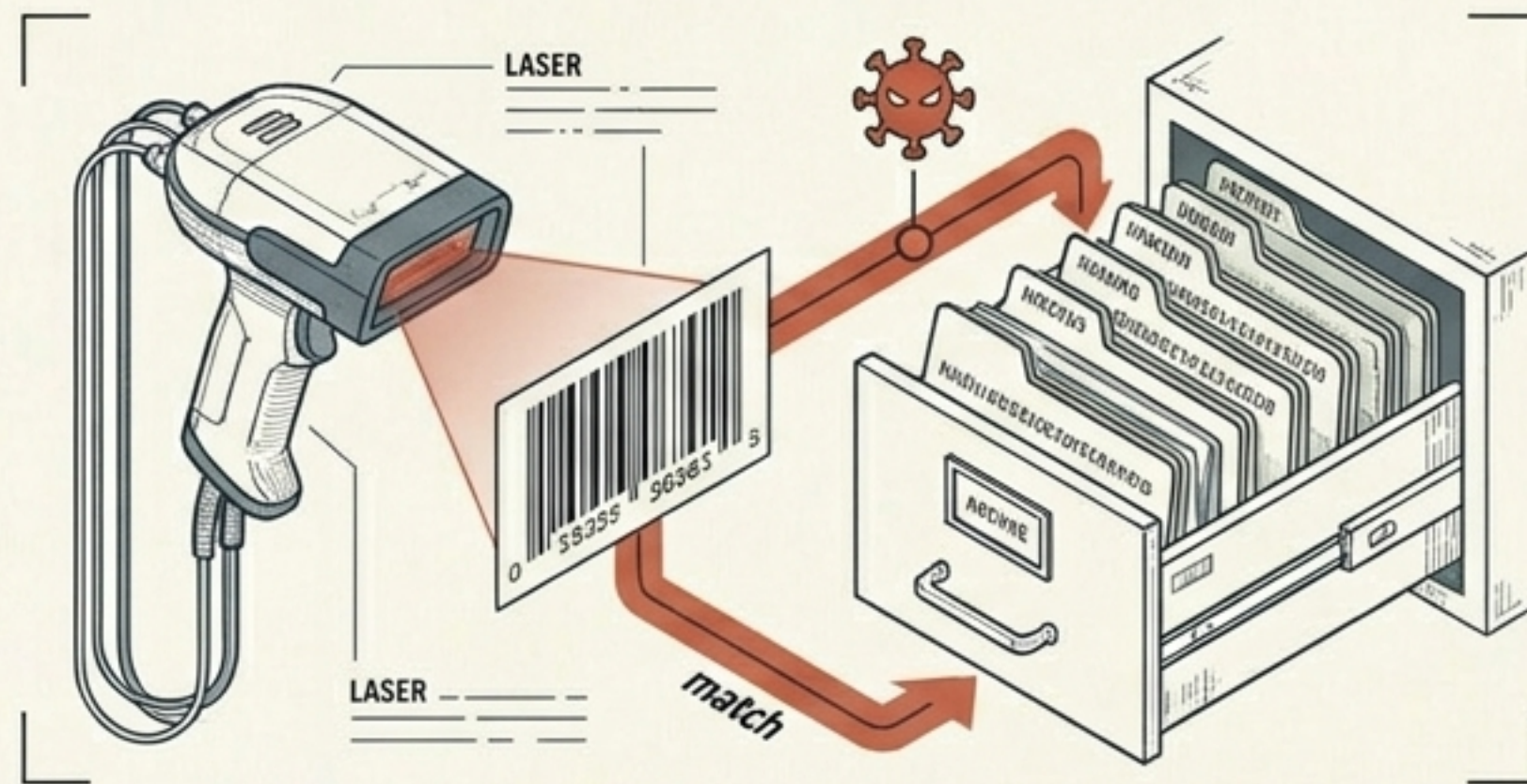
ניתוח דינמי והיורסטי (Dynamic/Heuristic)



השיטה: 'מעקב התנהגותי'. ניטור בזמן אמת של פעולות התוכנה בעת ריצתה. אם תוכנה לא מוכרת מנסה למחוק מנסה נזדה למחוק קובץ מערכת – היא תיחסם.

היתרון: מסוגל לעצור התקפות חדשות לחלוטין על בסיס חיפוש תבניות אבנורמליות.

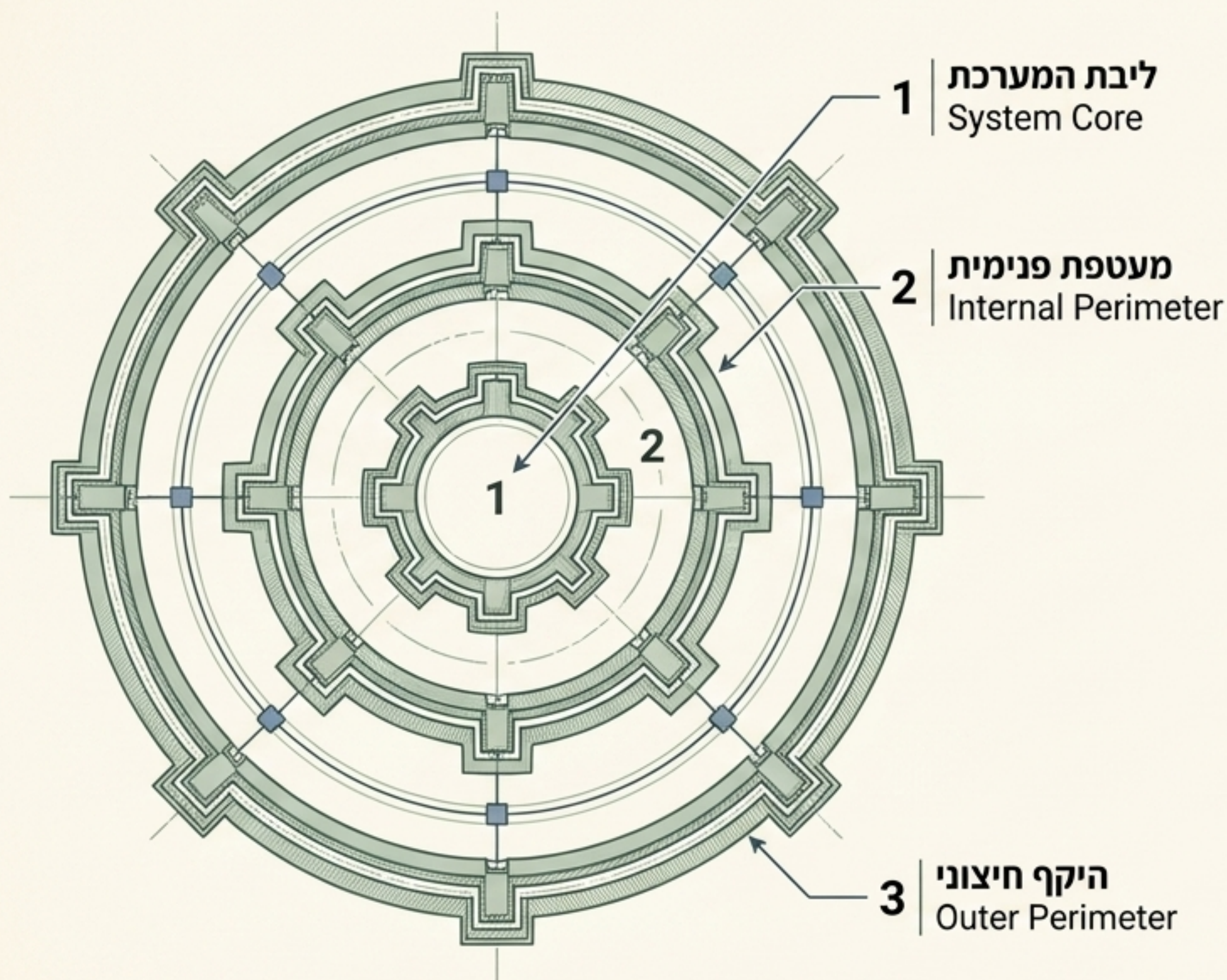
ניתוח סטטי (Static Analysis)



השיטה: 'מסדר זיהוי'. סריקת קוד התוכנה, הפקת חתימה דיגיטלית, והשוואתה למאגר קיים של נוזקות מוכרות.

נקודת תורפה: המערכת עיוורת לחלוטין לנוזקות מסוג Zero-day שעוד לא קוטלגו בעולם.

ארגון ההגנה: אסטרטגיות סיכול (Mitigation)



1. בידוד וירטואלי | Sandboxing

כליאת אפליקציות ודפדפנים בסביבה מבוקרת. קוד זדוני שחודר נשאר כלוא ב'ארגז חול' ללא יכולת לגשת לליבת המערכת.



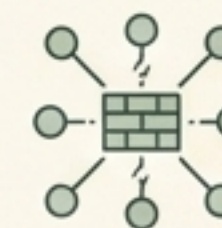
2. ניטור וסגר | Real-Time Protection

תוכנת אנטי-וירוס ברמת הליבה (Kernel) הבוחנת בזמן אמת תהליכים ניגשים לזיכרון וחותכת אותם (Quarantine) בטרם ביצוע פקודה הרסנית.



3. חומת היקף | Network Segregation

פיצול הרשת הארגונית לתת-רשתות מבודדות. מונע מתולעת שנכנסה למחלקת השיווק לזחול אוטומטית לשרתי הייצור.



המפלט האחרון וגבולותיו: בידוד רשת (Air Gap)

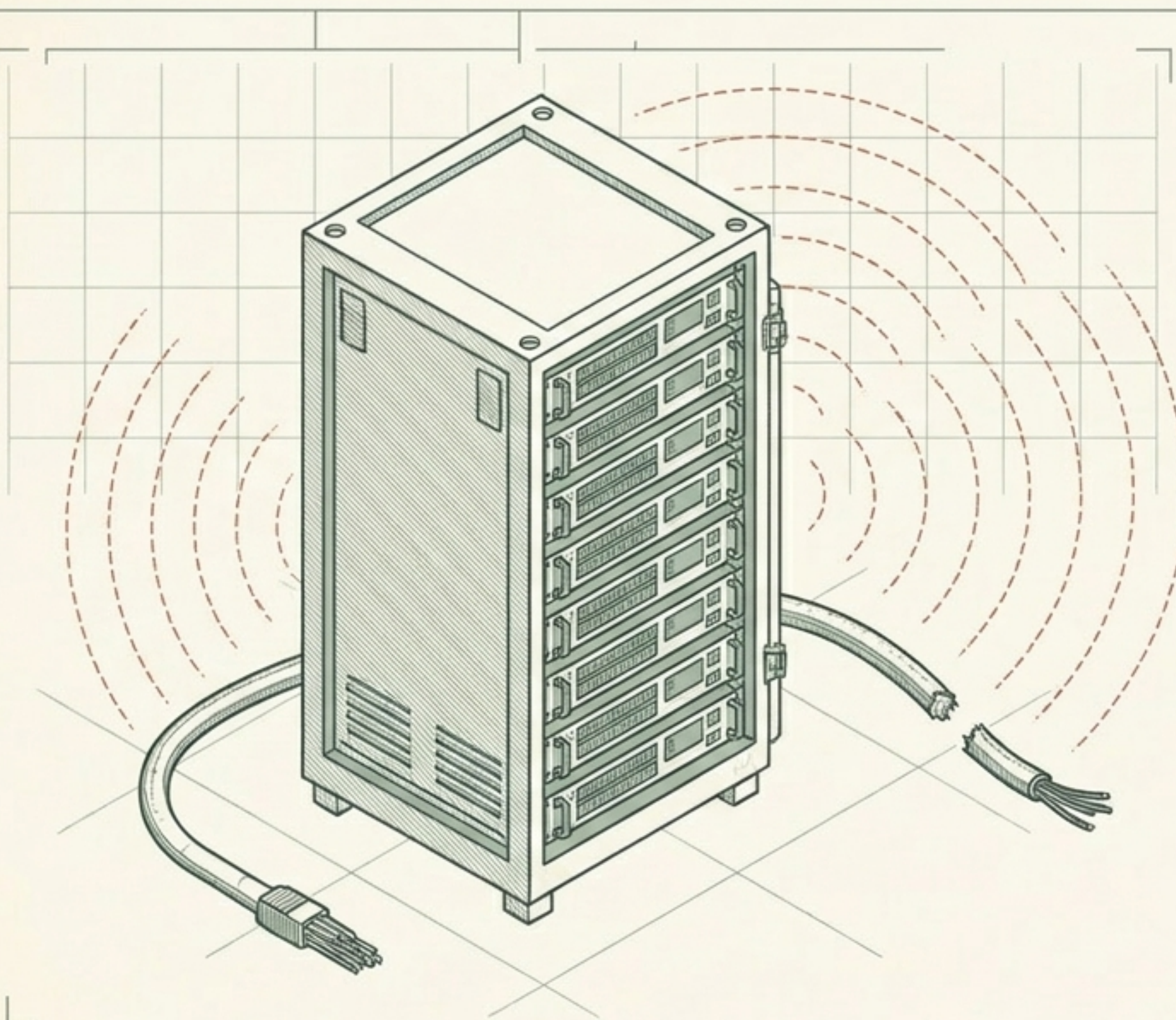
הקונספט: נתק מוחלט

המחשב מנותק פיזית מכל חיבור רשת (Air Gap)
הדרך היחידה להחדיר מידע היא פיזית (למשל כונן
כונן USB בפרשת Stuxnet).

אנומליות מחקר: פריצת הבידוד באוויר

חוקרים הדגימו יכולת לחלץ מידע מתוך מערכות
מבודדות אפילו ללא חיבור אינטרנט או כבל, תוך
שימוש בערוצים נסתרים:

- **AirHopper**: זליגת נתונים מגלי רדיו הנפלטים
מתדרי זיכרון (RAM).
- **BitWhisper**: מניפולציה וקריאה של פליטת חום
ממחשבים קרובים.
- **Fansmitter**: שידור נתונים באמצעות גלי קול
המופקים על ידי מאווררי המארז.



חברות	רמות גבוהות	סלולריות	תשתיות	רשתות

מערכת סגורה: מחזור החיים של מתקפת סייבר

1. פגיעות (Vulnerability)

משתמש מקבל דוא"ל ומנצל באג או חולשת פריבילגיות בדפדפן המארח.

3. הסוואה (Evasion)

ה-Dropper מושך Backdoor ומפעיל Rootkit לכיסוי עקבות. ניתוח סטטי נכשל מול התנהגות Fileless.

2. חדירה (Infiltration)

סוס טרויאני מתחזה לקובץ תקין ומופעל. הוא נושא עמו מטען קל מסוג Dropper לתחילת התבססות.

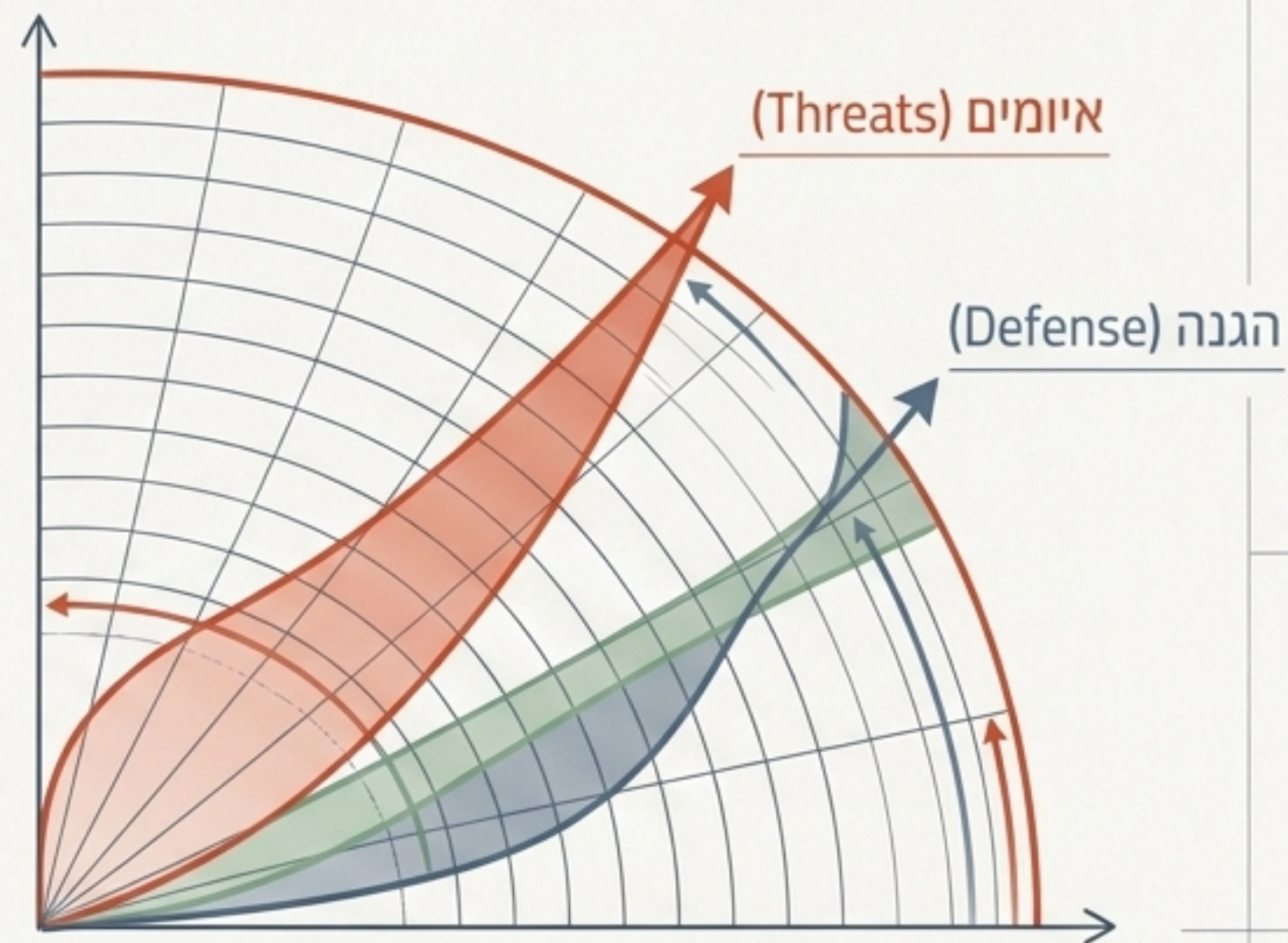
4. מכת מחץ (Execution)

הגישה מנוצלת להחדרת כופרה (Ransomware), העוקפת את הגנות פיצול הרשת באמצעות הרשאות שנגנבו.

חיסומ	רמת גורם	רמת גורם	רמת גורם	רמת גורם

אופק האיום: מרוץ החימוש של מחר

- זינוק במחקר האקדמי: התחום צומח בקצב של 34.1% מדי שנה כדי להדביק את הפער.
- האתגר - אוטומציית תקיפה (AI Malware): מערכות אוטונומיות הלומדות לחמוק מסביבות בידוד ומשנות קוד בזמן אמת.
- חזית ההגנה (ML Defense): אימוץ מודלי למידת מכונה לניתוח התנהגותי היוריסטי מול מתקפות אפס-ימים (Zero-Day).



הנוזקות של המחר לא יסתמכו על תמימות משתמשים, אלא על למידת מכונה. על מערכת החיסון הדיגיטלית להתפתח ולפעול מהר יותר מהנגיף שהיא מנטרת.